

Suposições

- Supõe-se que os colaboradores apresentem uma literacia e formação em cibersegurança inferiores aos dos responsáveis máximos (CIO, CEO, CFO), que beneficiam de formação específica nessa área.
- Supõe-se risco acrescido na rede devido à presença de Firewalls antigos, potencialmente com vulnerabilidades conhecidas e suporte limitado.
- Supõe-se que a arquitetura centralizada (ERP) impeça acessos não autorizados. No entanto, o comprometimento de uma única conta com privilégios elevados pode expor toda a infraestrutura.
- Supõe-se que a direção subestima o risco reputacional, focando-se apenas em custos financeiros imediatos.

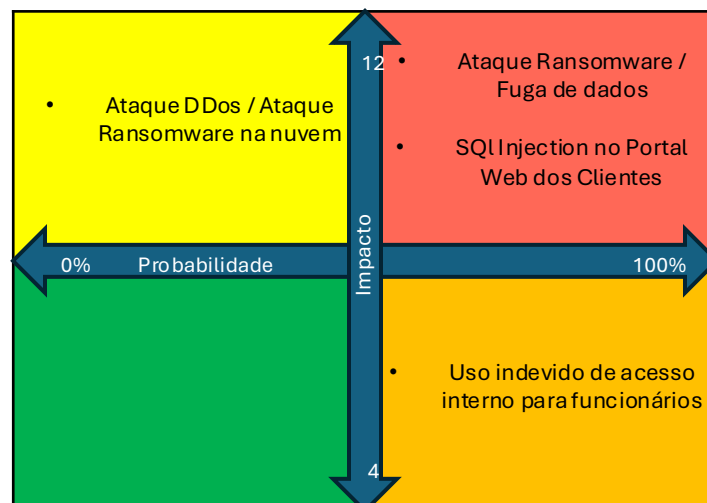
Ativos Críticos e avaliação

Ativo Crítico	Valor Estimado	Observações
Base de dados do registo dos pacientes	\$200 * 4M = \$800M + (multas até \$50M)	Contém dados pessoais, financeiros e clínicos sensíveis.
Sistema de backup de dados	>\$800M	Os dados são armazenados por entidades exteriores e o contrato ainda não está totalmente disponível.
Repositório de imagens	\$11M + (multas até \$50M)	\$11M por incidente é o custo médio de violação dos cuidados de saúde de acordo com o relatório da IBM. Repositório com ~6M de ficheiros sensíveis.
Portal Web dos pacientes	\$11M	Não se trata só de valores monetários, mas também tem um impacto reputacional elevado na aquisição de novos clientes, cerca de 20%.
Infraestrutura de rede	(\$7.5M / 24h) + (\$15.000 / minuto)	Se o sistema estiver indisponível durante 24 horas, a perda estimada é de \$7.5 M e mais \$15.000 por minuto de inatividade da nuvem, além disso, indisponibilidades superiores a 2 horas podem interromper tratamentos críticos nos hospitais.
Plataforma de acesso interno para funcionários	\$11M	Contém os dados pessoais dos funcionários e a gestão das funções.

Classificação de registo de Riscos

Rank	Risco	Ativo afetado	Probabilidade	Consequência	Nível Crítico	Observações
1	Ataque Ransomware / Fuga de dados	Base de dados dos pacientes	0.6 anual 0.35 anual por organização	Perda de dados sensíveis e confiança dos clientes	Alto	Valor 0.6/ano indicado pela equipa de IT, além disso ainda há a probabilidade de 0.35/ano por organização. Os ataques de Ransomware em hospitais têm frequências elevada, ou seja, em cada 10 organizações cerca de 6 são atacadas por ano.
2	Ataque DDoS / Ataque Ransomware na nuvem	Sistema da empresa	- Fornecedor 1: 0.2 - Fornecedor 2: 0.25 - Fornecedor 3: 0.1 35% em relação ao ano anterior	Interrupção de tratamentos e operações hospitalares	Alto	Probabilidade com base nos dados dos fornecedores Cloud, há um aumento de 35% nos ataques DDoS em relação ao ano anterior na área da saúde. Além de cada fornecedor dar a sua probabilidade para os ataques de Ransomware.
3	SQL Injection/ ausência de 2FA	Portal web dos clientes	~ 0.7 anual	Acesso indevido e manipulação de dados de pacientes	Alto	Foram encontradas vulnerabilidades de SQL Injection no Portal web dos clientes e no relatório não foi confirmado se foi corrigida, além disso muitos clientes não têm o 2FA ativo. Como as falhas são reais e não há evidência de mitigação, a probabilidade de exploração é alta, ~0.7/ano. Tendo como referência 0.6/ano (equipa de IT) e 0.35/ano (setor).
4	Uso indevido de acessos internos (role creep)	Plataforma de acesso interno para funcionários	75% (Muito alta)	Exposição não autorizada de dados ou sabotagem interna	Médio	75% dos incidentes em saúde resultam de erro humano ou abuso interno. E além disso existe políticas de senha fraca em muitas contas.
5	Ataque DDoS / Ataque Ransomware na nuvem / Fuga de dados	Sistema ERP corporativo na sede	~0.1 anual (Baixa)	Paragem total das operações	Médio	Por ser um sistema centralizado, existe risco de falha total caso a infraestrutura de nuvem seja comprometida. Embora a probabilidade ser baixa, o impacto seria elevado, podendo assim interromper todas as operações da organização.

Matriz de risco



Reflexão

A migração para a cloud representa um avanço estratégico significativo para a inovação e eficiência operacional, alinhando-se com a visão arrojada da CEO. No entanto, aumenta substancialmente a exposição a riscos.

Os ativos críticos e valiosos exigem controlos mais robustos, para proteger dados sensíveis. A base de dados do registo dos pacientes é o ativo mais valioso e requer uma maior atenção e proteção.

As principais vulnerabilidades incluem ataques de Ransomware e DDoS (alto impacto financeiro e operacional), SQL Injection (afeta o portal web dos pacientes) e o erro humano, responsável por 75% dos incidentes no setor. A migração do sistema para a cloud também implica uma maior dependência de fornecedores externos, aumentando a exposição do sistema. Por isso, é necessário rever os contratos com os fornecedores.

Recomenda-se que a migração deve ser acompanhada da implementação de controlos robustos, como:

- Formação contínua dos funcionários;
- Teste de intrusão mais frequentes;
- Maior controlo na gestão de acessos;
- Monitorização contínua das operações;
- Estabelecimento e atualização de políticas de resposta a incidentes.

A segurança deve ser uma prioridade estratégica, pois permite atingir os objetivos da empresa, garantir a confiança dos pacientes e sustentar a reputação da empresa.